RESULTADOS DO ESTUDO PILOTO

Influência da especificação de requisitos na segurança e na correção funcional de código gerado por modelos de linguagem

Andre Lucas Francino Castelo Branco

Orientador: Mauro José Araújo de Melo

Engenharia de Software - iCEV

Versão parcial para orientação - 3 de novembro de 2026

4 RESULTADOS DO ESTUDO PILOTO

4.1 Composição e cobertura

O piloto reuniu 72 implementações, correspondentes a três tarefas, quatro níveis de especificação, dois modelos e três repetições por combinação. As tarefas foram login (T01), busca de produtos (T02) e consulta de pedidos (T06). Cada modelo contribuiu com 36 gerações. Foram utilizados gpt-4.1-mini-2025-04-14 e gpt-5.4-mini-2026-03-17, nas condições descritas na metodologia.

Os 72 registros disponíveis contêm respostas válidas de geração, mas essa condição não implica execução bem-sucedida dos programas. A análise estática abrangeu todas as implementações. Os testes comportamentais de segurança examinaram as 48 gerações de T01 e T06; a bateria ampliada de aceitação funcional abrangeu as três tarefas e registrou 1.797 resultados de casos nas execuções concluídas. A unidade de análise permanece a geração.

Os resultados apresentados nesta seção são exploratórios. Os testes ampliados foram definidos após a coleta e incluem convenções documentadas de execução e adaptação. A coleta adicional da T04, apresentada em 4.6, possui registros próprios e não foi incorporada aos denominadores do piloto.

4.2 Análise estática

O Bandit registrou quatro ocorrências da regra B105, associadas a CWE-259, em duas implementações de T06. As ocorrências apontam tokens fixos nos exemplos de código g34 e g36. O Semgrep não produziu alertas na configuração p/python utilizada. Assim, o conjunto contém quatro alertas em duas gerações, e não quatro gerações classificadas como vulneráveis.

Tabela 1 - Cobertura e alertas estáticos

Ferramenta	Gerações analisadas	Alertas	Gerações com alerta
Bandit	72	4	2
Semgrep	72	0	0

Fonte: registros de analisadas e achados em resultados.db (2026).

Os alertas permanecem sujeitos a revisão humana. A presença de tokens demonstrativos exige um critério explícito de classificação; sem essa revisão, os números descrevem ocorrências dos analisadores. Da mesma forma, a ausência de alertas de autorização não representa aprovação dessa propriedade.

4.3 Acesso a pedidos de outro usuário

Os testes de T06 observaram exposição de pedidos nas seis gerações N0. Cada uma retornou dados de um pedido solicitado sob a identidade de outro usuário. Nas demais condições, houve 13 aprovações no critério de acesso cruzado e cinco avaliações inconclusivas. A Tabela 2 apresenta a distribuição por nível, agregando os dois modelos.

Tabela 2 - Resultado de autorização em T06

Nível	Aprovação no acesso cruzado	Exposição observada	Inconclusivo	Total
N0	0	6	0	6
N1	5	0	1	6
N2	5	0	1	6
N3	3	0	3	6

Fonte: verificações comportamentais mais recentes por geração (2026).

A aprovação exigiu controles positivos de acesso do proprietário. As avaliações inconclusivas decorreram de impedimentos de execução ou de falhas nesses controles, sem serem convertidas em proteção aprovada. Nos casos com substituição de dependências, o resultado se refere à autorização sob identidades de teste e não à segurança do autenticador original. A exigência adicional de N3 por resposta 404 foi registrada separadamente do bloqueio básico de acesso.

Nenhum alerta estático correspondeu às seis exposições identificadas nessa tarefa. O contraste evidencia uma diferença de cobertura entre os instrumentos empregados, sem estabelecer impossibilidade geral de detecção estática de falhas de autorização.

4.4 Bloqueio de tentativas de login

Em T01, cinco das seis gerações N3 bloquearam tentativas por conta e por IP no critério de 25 tentativas em até 60 segundos. A outra geração N3 apresentou travamento. Nos níveis N0 e N1, não foi observado bloqueio nesse limiar; em N2, cinco gerações não bloquearam e uma permaneceu inconclusiva.

Tabela 3 - Bloqueio em T01, agregado entre modelos

Nível	Bloqueio observado	Sem bloqueio no limiar	Inconclusivo	Total
N0	0	6	0	6
N1	0	6	0	6
N2	0	5	1	6
N3	5	0	1	6

Fonte: verificações comportamentais (2026). Os valores coincidiram nos critérios por conta e por IP, avaliados separadamente; a tabela representa 24 gerações.

O travamento não foi contado como bloqueio eficaz, pois impediu o controle funcional. Os resultados também não indicam ausência de qualquer política de limitação nas demais amostras: limites superiores ao número de tentativas aplicado não são cobertos por esse teste.

4.5 Aceitação e diagnóstico funcional

No grupo de capacidades mínimas, 57 gerações foram aprovadas, nove reprovadas e seis permaneceram sem execução conclusiva. A distribuição por tarefa está na Tabela 4. A classificação exige aprovação de todos os casos do grupo; as convenções do contrato detalhado e os testes adicionais de robustez possuem resultados próprios no repositório.

Tabela 4 - Aceitação funcional mínima por tarefa

Tarefa	Aprovadas	Reprovadas	Sem execução conclusiva	Total
T01	22	1	1	24
T02	16	5	3	24
T06	19	3	2	24
Total	57	9	6	72

Fonte: bateria ampliada de aceitação, registros mais recentes por geração (2026).

A inspeção dos casos identificou causas diferentes. Três implementações de T06 passaram em uma condição diagnóstica com Pydantic 1 e falharam com Pydantic 2. Em T01, foi reproduzido um travamento por aquisição repetida de um bloqueio não reentrante. Também ocorreram dependências incompletas e usos de interfaces de bibliotecas

incompatíveis com o ambiente principal. Os códigos originais e os resultados principais foram preservados; as condições de sensibilidade estão documentadas à parte.

Essas ocorrências impedem atribuir todas as reprovações ao acréscimo de requisitos de segurança. A bateria mostra o atendimento dos casos no ambiente escolhido, enquanto a identificação da causa exige exame da implementação e de suas dependências. Nenhuma medida inferencial foi utilizada nesta etapa para confirmar perda funcional entre níveis.

4.6 Validação adicional da T04

Após o piloto, foi construída a tarefa T04, de download de arquivos, para validar a ampliação dos instrumentos. Sete aplicações de referência foram executadas em Linux, incluindo implementações protegidas, variantes vulneráveis e controles que rejeitam todas as solicitações ou devolvem bytes incorretos. O verificador distinguiu os comportamentos esperados, inclusive a abertura de arquivo externo seguida de resposta 404. A criação de links simbólicos foi possível nesse ambiente, suprindo a cobertura não executada no Windows.

Uma coleta exploratória separada reuniu oito gerações, uma por nível e modelo. Os prompts, a ordem sorteada, os parâmetros e a imagem foram registrados antes das chamadas. Uma falha de persistência no OneDrive exigiu emenda de gravação, documentada sem alteração das condições de avaliação e sem regeneração das respostas. Houve oito requisições para as oito amostras.

Sete amostras passaram nos cinco downloads legítimos. Uma apresentou erro 500 nesses casos. Em outra, o download legítimo funcionou, mas o acesso por link simbólico retornou um arquivo externo. As duas amostras N3 passaram nos nove casos de segurança executados. Esses resultados confirmam o exercício do fluxo e de seus controles, mas uma repetição por condição não sustenta comparação estatística entre níveis.

Os resultados da T04 permanecem fora das tabelas do piloto. O banco original, os relatórios por geração e o material da coleta adicional estão disponíveis no repositório da pesquisa: https://github.com/Andre-PI/tcc-requisitos-seguranca-llms. As contagens podem ser conferidas sem executar as aplicações geradas pelo script conferir_pacote.py.